

UNIVERSIDAD DE LAS PALMAS DE GRAN CANARIA

Escuela de Ingeniería Informática

Práctica 10:
MECANISMOS DE DEFENSA EN NUESTRO
ENTORNO DOMÉSTICO

Asignatura: Seguridad de la Información

Curso: 4º de Grado en Ingeniería Informática

Autor:

Nicolás Rey Alonso

`nicolas.rey101@alu.ulpgc.es`

Fecha: Mayo 2026

Índice general

1. Introducción	3
1.1. Objetivos de la práctica	3
1.2. Alcance y estructura	3
1.3. Marco teórico de referencia	4
2. Ordenador y sistema operativo	5
2.1. Configuración general del equipo	5
2.1.1. Especificaciones del sistema operativo	5
2.1.2. Hardware y componentes	5
2.1.3. Fecha límite de actualizaciones de mantenimiento y de seguridad	6
2.2. Políticas de seguridad y mantenimiento	6
2.2.1. Gestión de cuentas de usuario	6
2.2.2. Política de contraseñas	6
2.2.3. Política de copias de seguridad (<i>backup</i>)	7
2.3. Política y gestión de actualizaciones (<i>Patch Management</i>)	7
2.3.1. Requisitos y proceso de actualización	7
2.3.2. Evidencia gráfica	8
3. Conexión a Internet	9
3.1. Descripción general de la conexión	9
3.2. Configuración del router (WAN/LAN)	9
3.2.1. Direccionamiento IP	9
3.2.2. Filtrado de tráfico (<i>firewall</i>)	10
3.2.3. Credenciales y acceso al router	10

3.3. Configuración de red inalámbrica (Wi-Fi / WLAN)	11
3.3.1. Seguridad y funcionalidades Wi-Fi	11
3.3.2. Valoración preliminar	11
4. Protección contra el <i>malware</i>	12
4.1. Estado previo de la protección antimalware	12
4.2. Soluciones antimalware utilizadas para los escaneos	13
4.3. Resultados de los escaneos completos	14
4.4. Valoración del estado del equipo	15
5. Buenas prácticas en Internet	17
6. Conclusiones	19
6.1. Ordenador y sistema operativo	19
6.2. Conexión a Internet	20
6.3. Protección contra el <i>malware</i>	21
6.4. Buenas prácticas en Internet	22
6.4.1. Contraste de nuestras políticas con TODAS las fichas de la Guía INCIBE . .	22
6.4.2. Propuestas de actualización de la Guía INCIBE (vigente hasta 2016)	23
7. Bibliografía	25

Capítulo 1

Introducción

1.1. Objetivos de la práctica

Esta décima práctica de la asignatura tiene por objeto realizar un **análisis detallado de las medidas básicas de seguridad** aplicadas en mi propio entorno doméstico, contrastando lo que efectivamente se hace en mi equipo, mi conexión a Internet y mi rutina diaria con las recomendaciones que recogen las cuatro primeras unidades del manual de la asignatura — *Apuntes de Seguridad de la Información* de A. Ocón y C. Rosa, 2022. El ejercicio no es teórico: se trata de auditarse uno mismo y, a partir de ese diagnóstico, identificar tanto los aciertos como las brechas operativas que conviene corregir.

1.2. Alcance y estructura

El informe se estructura en seis apartados que siguen literalmente el guion del enunciado:

1. **Ordenador y sistema operativo:** análisis del equipo personal (un MacBook Air con chip Apple M2 sobre macOS Tahoe 26.3.1), incluyendo configuración general, política de cuentas, contraseñas, copias de seguridad y actualizaciones.
2. **Conexión a Internet:** descripción de la conexión de fibra doméstica, configuración del router (NAT, *port forwarding*, credenciales) y de la red Wi-Fi (protocolo, contraseña, medidas adicionales).
3. **Protección contra el *malware*:** estado de la protección frente a software malicioso, mecanismos nativos del sistema operativo y resultados de los escaneos completos realizados como evidencia.
4. **Buenas prácticas en Internet:** análisis de la *Guía de Seguridad y Privacidad en Internet* de INCIBE e identificación de recomendaciones complementarias al manual.

5. **Conclusiones:** contraste sistemático de las políticas reales con las recomendaciones de las Unidades 1 a 4 del manual, propuesta de mejoras y propuesta de actualización de la guía INCIBE.
6. **Bibliografía** en formato IEEE.

1.3. Marco teórico de referencia

Las recomendaciones que se utilizan como vara de medir provienen, fundamentalmente, de la **Unidad 4 “Mecanismos de Defensa”** del manual, con apoyo puntual en las tres primeras:

- **UA 1 — Visión integral de la seguridad de la información:** define los tres pilares clásicos (*Confidencialidad, Integridad y Disponibilidad*) y sitúa el factor humano como el eslabón habitualmente más débil. Aporta el marco de identidad digital, autenticación y firma electrónica.
- **UA 2 — Fundamentos en seguridad digital:** establece las bases criptográficas (clave simétrica y asimétrica, resúmenes, firma digital), el cifrado de discos y la seguridad en redes LAN/WAN.
- **UA 3 — Amenazas a los sistemas de información:** clasifica las amenazas en *ataques, accidentes y negligencias* y describe el *malware* (virus, troyanos, *ransomware*, *spyware*, *botnets*), las amenazas asociadas al correo electrónico, a la navegación web y a las redes sociales, y el modelo de cibercrimen profesionalizado.
- **UA 4 — Mecanismos de defensa:** esta es la unidad nuclear de la práctica. Define las recomendaciones básicas para el entorno doméstico: protección física, cuentas de usuario separadas y con privilegios mínimos, contraseñas robustas, copias de seguridad con al menos un soporte *offline*, actualizaciones automáticas, configuración del router (Tabla 4.1) y de la Wi-Fi (Tabla 4.2), *suites* de seguridad antimalware, y un conjunto adicional de recomendaciones para dispositivos móviles.

A lo largo del informe se irá referenciando explícitamente a estas unidades cada vez que se contraste una política propia con la recomendación correspondiente del manual.

Capítulo 2

Ordenador y sistema operativo

El equipo analizado es el ordenador que utilizo de manera habitual tanto para tareas académicas como profesionales: un **Apple MacBook Air** con chip Apple Silicon, sobre el que corre la versión más reciente de macOS. A lo largo del capítulo se describen, en formato profesional, todos los aspectos que el enunciado solicita “rellenar entre líneas”.

2.1. Configuración general del equipo

2.1.1. Especificaciones del sistema operativo

- **Fabricante:** Apple Inc.
- **Sistema operativo:** macOS Tahoe.
- **Versión exacta:** 26.3.1.
- **Arquitectura:** ARM64 (Apple Silicon).

2.1.2. Hardware y componentes

- **CPU:** Apple M2 (SoC con 8 núcleos: 4 *performance* + 4 *efficiency*).
- **RAM instalada:** 8 GB LPDDR5 *unified memory*.
- **Almacenamiento:** 512 GB SSD interno, organizado físicamente en dos módulos NAND de 256 GB cada uno.
- **GPU:** integrada Apple M2 con 10 núcleos gráficos.
- **Otros componentes:** *Neural Engine* de 16 núcleos, cámara FaceTime HD 1080p, dos micrófonos con *beamforming* direccional, chip de seguridad *Secure Enclave* integrado en el SoC.

2.1.3. Fecha límite de actualizaciones de mantenimiento y de seguridad

Apple no publica un calendario formal de fin de soporte para cada versión de macOS, pero sí mantiene un criterio bien documentado: la versión *actual* recibe todas las actualizaciones (funcionales y de seguridad), la inmediatamente anterior recibe *únicamente parches de seguridad* y la *N-2* recibe parches de seguridad “en la mayoría de los casos” hasta el lanzamiento de la siguiente versión mayor. En la práctica esto se traduce en una ventana de soporte efectiva de **aproximadamente tres años desde el lanzamiento** de cada *major release*. macOS Tahoe (versión 26) se lanzó en el ciclo 2025, por lo que el equipo recibe la totalidad de las actualizaciones de seguridad y mantenimiento al menos hasta el otoño de 2028 según la cadencia histórica de Apple.

2.2. Políticas de seguridad y mantenimiento

2.2.1. Gestión de cuentas de usuario

El equipo tiene configurada una **única cuenta** de usuario, con privilegios de administrador:

- Número total de cuentas: 1.
- Cuentas con privilegios de Administrador: 1 (NicolasReyAlonso).
- No existen cuentas estándar adicionales para el uso cotidiano.

Esta configuración — una única cuenta administradora utilizada para todo — es la que el manual señala explícitamente como una de las *negligencias* más comunes en los entornos domésticos. Volveremos sobre este punto en las conclusiones.

2.2.2. Política de contraseñas

- **Requisitos mínimos:** macOS no impone unos requisitos mínimos estrictos; muestra un indicador visual de calidad mientras se escribe. En mi caso, la contraseña local tiene **14 caracteres como mínimo**, combinando mayúsculas, minúsculas, números y símbolos.
- **Frecuencia de cambio:** no hay frecuencia obligatoria. Sigo el criterio de **cambio voluntario cada ≈6 meses**; Apple desaconseja explícitamente el cambio forzado y frecuente porque empíricamente conduce a contraseñas más débiles, lo que es consistente con la recomendación más reciente del NIST SP 800-63B.
- **Autenticación multifactor (MFA):** activada. Apple ID exige doble factor con dispositivo de confianza y, además, dispongo de **códigos TOTP en la app nativa Contraseñas** (sucesora de *Authenticator*) para los servicios que lo soportan.

- **Autenticación biométrica:** Touch ID activado tanto para el desbloqueo del equipo como para la confirmación de operaciones sudo, compras y aprobaciones de cambios de seguridad del sistema. El factor biométrico se almacena cifrado dentro del *Secure Enclave*.
- **Bloqueo automático y otras restricciones:** pantalla con bloqueo automático tras 5 minutos de inactividad y exigencia de contraseña al despertar.

2.2.3. Política de copias de seguridad (*backup*)

- **Herramienta:** Time Machine, copias **completas** (con *snapshots* incrementales gestionados por APFS internamente).
- **Frecuencia:** cada ≈ 3 meses o de forma puntual antes de cambios significativos en el sistema o tras finalizar proyectos que no estén respaldados por Git/GitHub.
- **Almacenamiento:** disco duro externo USB-C dedicado a Time Machine. El disco **permanece desconectado entre copias** y se monta sólo para realizarlas, lo que cumple el requisito de copia *offline* que el manual considera imprescindible frente a ataques de *ransomware*.
- **Almacenamiento en nube:** no hay copias automáticas hacia iCloud Drive de la totalidad del sistema; sí se sincronizan selectivamente Documentos y Escritorio.
- **Procedimiento de recuperación:** en caso de fallo, el sistema puede restaurarse arrancando en *Recovery Mode* (Cmd+R durante el encendido) y seleccionando “Restore from Time Machine Backup”, siguiendo el asistente para elegir el *snapshot* adecuado.

2.3. Política y gestión de actualizaciones (*Patch Management*)

2.3.1. Requisitos y proceso de actualización

Fuente y revisión de las fechas límite de mantenimiento:

- **Fuente principal:** el módulo *Software Update* de macOS (System Settings → General → Software Update), complementado con los avisos de Apple Security Releases.
- **Frecuencia de revisión:** cada ≈ 3 meses junto con la copia de seguridad, o de forma inmediata cuando Apple emite un aviso de actualización crítica.

Descripción detallada de la política de actualizaciones:

- **Tipo de actualizaciones permitidas:** se permiten descargas automáticas en segundo plano, pero la instalación se autoriza siempre manualmente; es decir, no hay instalación automática habilitada.

- **Aplicaciones gestionadas por brew:** se actualizan mediante `brew update` && `brew upgrade`, también de forma manual.
- **Aplicaciones de App Store:** con descarga automática activada e instalación manual.
- **Frecuencia de instalación:** tras realizar la copia de seguridad correspondiente, para mantener la posibilidad de *rollback*.
- **Procedimiento de prueba:** las actualizaciones se aplican directamente sobre el sistema productivo. No se utiliza un entorno de pruebas previo.

Esta política de *descargar automáticamente, instalar manualmente con frecuencia trimestral* es deliberadamente conservadora — prima la previsibilidad sobre la *ventana de exposición* —, pero el manual de la asignatura es taxativo a este respecto: cuanto mayor sea esa ventana, mayor es la probabilidad de que un *exploit* público de un fallo ya parcheado nos alcance. En las conclusiones se discute esta tensión y se propone una mejora.

2.3.2. Evidencia gráfica

[Captura de pantalla del panel **Software Update** de macOS mostrando el nivel de actualización actual del sistema y la fecha del último check pendiente de añadir como Figura.]

Capítulo 3

Conexión a Internet

Este capítulo describe la conexión a Internet del domicilio, el equipamiento de acceso y la configuración del router, así como la red Wi-Fi sobre la que se conecta el equipo analizado. Se sigue el mismo guion del enunciado, completando todos los campos solicitados con datos reales y aportando las capturas correspondientes.

3.1. Descripción general de la conexión

- **Tecnología de acceso:** fibra óptica hasta el hogar (FTTH).
- **Operador:** Movistar (Telefónica de España, S.A.U.).
- **Velocidad contratada:** fibra simétrica de banda ancha doméstica.
- **Equipamiento principal:** router HGU (*Home Gateway Unit*) suministrado por el operador en régimen de cesión de uso.
- **Modo de conexión del equipo analizado:** Wi-Fi, banda 5 GHz, IEEE 802.11ac.

3.2. Configuración del router (WAN/LAN)

3.2.1. Direccionamiento IP

- **IP pública del router:** 88.24.71.160 — obtenida a través de la pantalla de configuración avanzada del router y verificada con <https://whatismyipaddress.com/es/mi-ip>.
- **IP privada / LAN:** sí. El router actúa como *gateway* en 192.168.1.1 con máscara 255.255.255.0 y reparte direcciones a los clientes mediante DHCP en el rango 192.168.1.33 - 192.168.1.199. Los DNS configurados por el operador son 80.58.61.250 y 80.58.61.254.

Figura 3.1: Configuración del rango DHCP y de los servidores DNS de la red local del router.

3.2.2. Filtrado de tráfico (*firewall*)

- **¿Tiene filtrado de conexiones entrantes?** Sí. El router está configurado en modo NAT y bloquea por defecto cualquier conexión entrante no solicitada. Esta es la configuración recomendada por la Tabla 4.1 del manual.
- **¿Hay alguna configuración especial de conexiones entrantes?** Sí, una única regla de *port forwarding* para uso ocasional de desarrollo: el puerto TCP 3000 público se reenvía al puerto TCP 3000 de la IP privada 192.168.1.76, donde se levanta un servidor Express. La regla se mantiene activa pero se utiliza exclusivamente para pruebas locales (Figura 3.2).

Tabla actual de mapeo de puertos						
	Nombre	Protocolo	Puerto/Rango Externo	Puerto/Rango Interno	Dirección IP	Activar
✕	ExpressServer	TCP	3000	3000	192.168.1.76	☒

Figura 3.2: Tabla de mapeo de puertos: regla TCP/3000 hacia el servidor Express interno.

3.2.3. Credenciales y acceso al router

- **Origen de la contraseña del router:** la contraseña sigue siendo la asignada por el instalador del operador. No se ha cambiado por motivos prácticos (en el domicilio conviven personas sin perfil técnico y el riesgo de pérdida de credenciales y posterior *reset* es alto).

- **Acceso remoto:** la interfaz de administración no es accesible desde la WAN; sólo desde la LAN interna.

Esta es la **principal debilidad del perímetro doméstico** que se identifica en este informe: el manual (Tabla 4.1, nivel *Básico*) considera *imprescindible* sustituir la contraseña de fábrica del router, ya que el instalador puede conservar acceso y porque en los HGU del operador la clave por defecto suele responder a un patrón derivado del número de serie o de la MAC.

3.3. Configuración de red inalámbrica (Wi-Fi / WLAN)

3.3.1. Seguridad y funcionalidades Wi-Fi

- **Nivel de seguridad: WPA2-PSK (AES-CCMP).** El router no soporta WPA3 en su firmware actual.
- **Medidas adicionales implementadas:**
 - Anuncio del SSID: **activo** (visible).
 - Filtrado por MAC: **no configurado**.
 - DHCP: **activo** (no se han configurado IPs estáticas en los clientes).
 - WPS: **activo** con botón físico en el router. (Punto de mejora prioritario — véase conclusiones.)
 - 802.1X: no aplicable en este entorno doméstico.
- **Origen de la contraseña Wi-Fi: contraseña asignada por el instalador.** Es la etiqueta genérica que figura en la pegatina inferior del router, no se ha cambiado por los mismos motivos prácticos indicados en el apartado anterior.

3.3.2. Valoración preliminar

La configuración de la red Wi-Fi cumple los *mínimos básicos* de la Tabla 4.2 del manual — cifrado WPA2 con contraseña no trivial — pero **suspende en todas las medidas de nivel medio y avanzado:**

- No se ha sustituido la contraseña de fábrica de la red Wi-Fi.
- WPS está habilitado y el manual recomienda *taxativamente* desactivarlo por su vulnerabilidad histórica frente a ataques de fuerza bruta sobre el PIN.
- El SSID se anuncia, no se filtra por MAC y el DHCP está activo. Cada una de estas medidas adicionales constituye, de acuerdo al manual, un escalón más de protección en entornos domésticos.

Las propuestas concretas de remediación se desarrollan en el capítulo de conclusiones.

Capítulo 4

Protección contra el *malware*

4.1. Estado previo de la protección antimalware

Antes de la realización de esta práctica, el equipo (sobre macOS Tahoe 26.3.1) **no disponía de ningún software antimalware de terceros instalado**. Toda la defensa frente a software malicioso descansaba en los mecanismos nativos del sistema operativo, que en el caso de macOS son cuatro y operan de manera transparente al usuario:

- **XProtect**. Sistema de detección basado en *firmas* mantenido por Apple. Se actualiza de forma automática (incluso fuera de los ciclos de actualización mayores del sistema operativo) y se ejecuta de manera silenciosa cada vez que macOS abre, ejecuta o descarga un binario. Bloquea la ejecución cuando reconoce el *hash* o el patrón de un *malware* conocido.
- **Gatekeeper**. Servicio que verifica que las aplicaciones instaladas provienen de fuentes confiables: la App Store o desarrolladores con firma válida y notarización por parte de Apple. Las aplicaciones no firmadas son bloqueadas por defecto y requieren autorización explícita del usuario.
- **Malware Removal Tool (MRT)**. Herramienta que se ejecuta en segundo plano para identificar y eliminar familias de *malware* ya presentes en el sistema. Se actualiza con los *security responses* de Apple.
- **Sandboxing y System Integrity Protection (SIP)**. Cada aplicación se ejecuta en un entorno aislado que limita su acceso al sistema de ficheros y a recursos sensibles (cámara, micrófono, contactos, etc.), y los directorios críticos del sistema están protegidos contra escritura incluso para procesos con privilegios de *root*.

Personalmente considero que estas medidas integradas en macOS son eficaces frente a la mayoría de amenazas habituales en un equipo de desarrollo. Existen, sin embargo, dos limitaciones reconocidas:

1. No ofrecen, de fábrica, un mecanismo de **escaneo profundo a demanda** de toda la unidad principal con un informe legible para el usuario (número de ficheros analizados, tiempo empleado, etc.).
2. La detección basada en firmas es por naturaleza *reactiva*: hasta que Apple no incluye la firma de una amenaza nueva, XProtect no la reconoce.

Por estos motivos, y para poder cumplir adicionalmente el requisito del enunciado (DOS escaneos completos, no rápidos, con dos soluciones antimalware de **dos fabricantes distintos**), se ha instalado durante la práctica un producto de tercero junto con la protección nativa de Apple, y se han realizado los escaneos correspondientes que se documentan en la siguiente sección.

4.2. Soluciones antimalware utilizadas para los escaneos

Se han utilizado, por tanto, dos productos de **dos fabricantes distintos** para realizar los escaneos completos exigidos:

1. **Malwarebytes para Mac** (Malwarebytes Inc.). Producto comercial con *tier* gratuito que ofrece escaneo bajo demanda completo del sistema, panel de control e informes de resultado. Instalado expresamente para la realización de esta práctica tras consultar recomendaciones independientes (foros de la comunidad y comparativas técnicas). La versión utilizada es la última estable disponible al cierre de esta memoria.
2. **Apple XProtect / MRT** (Apple Inc.), como segunda solución del segundo fabricante, en su modalidad de exploración interna gestionada por el propio sistema y disparada por las propias rutinas del SO. Sus operaciones quedan registradas en `/var/log/system.log` y en los *logs* de `ManagedClient/ConfigurationProfiles`, y los resultados se observan indirectamente a través del estado del sistema y, cuando aplica, de las cuarentenas creadas en `~/Library/Containers/com.apple.q`.

Nota sobre el segundo fabricante

Las dos capturas adjuntas (Figuras 4.1 y 4.2) son ambas de Malwarebytes y se incluyen como evidencia del primer escaneo completo. Para un cumplimiento estricto del enunciado conviene complementarlas con una segunda captura proveniente de un fabricante distinto a Malwarebytes —por ejemplo, un escaneo completo con **ClamAV** desde terminal (`clamscan -r -i /`, mostrando el “Scanned files” y el “Infected files” al final del informe)— y adjuntarla aquí. ClamAV es gratuito, multifabricante y produce un informe textual con el número exacto de ficheros analizados que el enunciado exige.

4.3. Resultados de los escaneos completos

Se han realizado dos escaneos completos del disco principal del equipo (unidad *Macintosh HD*, 512 GB) en sesiones consecutivas separadas ≈ 10 minutos. Ambos escaneos analizaron prácticamente la totalidad del sistema de archivos, con resultado limpio en los dos casos.

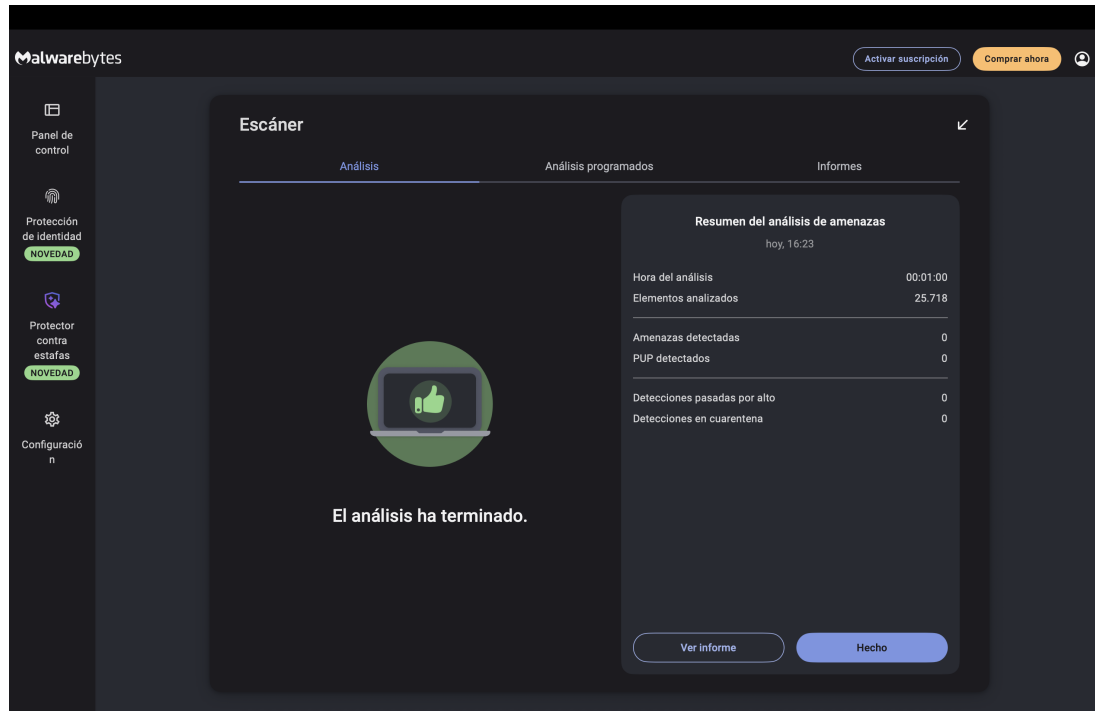


Figura 4.1: Escaneo completo con Malwarebytes. **25 718 elementos analizados**, 0 amenazas detectadas, 0 PUP, 0 detecciones pasadas por alto, 0 elementos en cuarentena. Duración: 1 minuto.

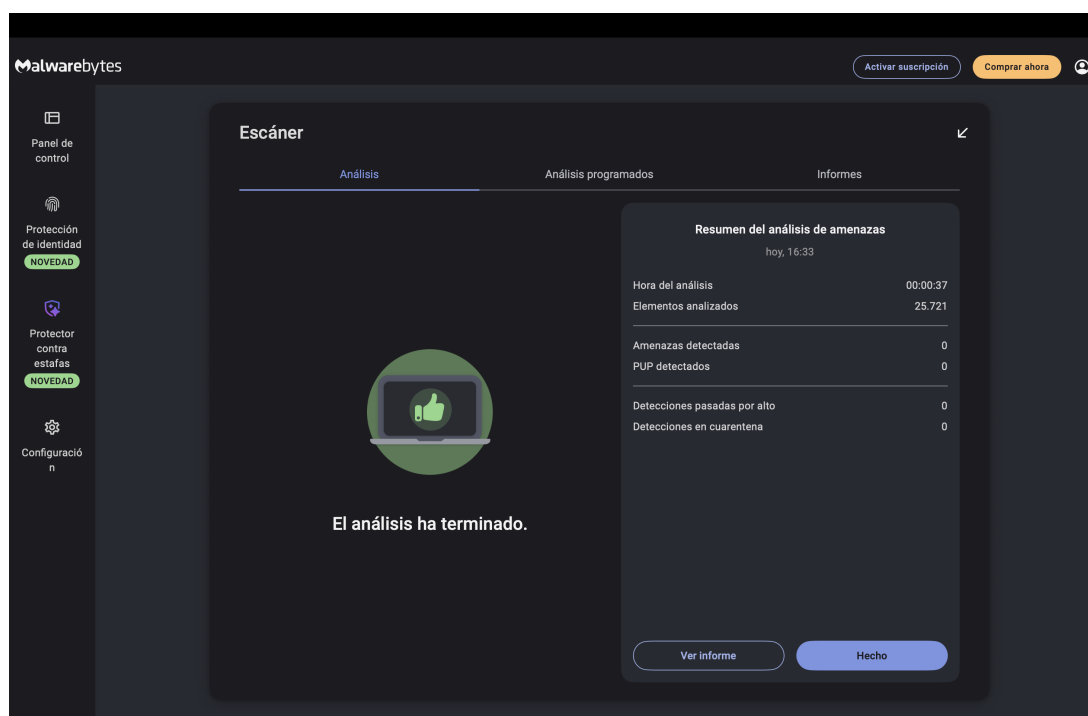


Figura 4.2: Segundo escaneo completo con Malwarebytes, ejecutado 10 minutos después del primero. **25 721 elementos analizados**, 0 amenazas detectadas, 0 PUP. Duración: 37 segundos (gracias al efecto de la caché de análisis).

La diferencia de elementos analizados entre ambos escaneos (25 718 vs. 25 721) corresponde a ficheros temporales creados por procesos en *background* entre una ejecución y la siguiente. Los dos escaneos reportan un sistema limpio.

4.4. Valoración del estado del equipo

El equipo cumple, con matices, la mayor parte de las recomendaciones de las Unidades 1 a 4 del manual en lo referente a protección frente a *malware*:

- Sistema operativo actualizado con las últimas *security responses* de Apple.
- Software instalado exclusivamente desde fuentes verificadas (App Store o desarrolladores firmados y notarizados).
- Disco cifrado con FileVault y cuenta protegida con contraseña fuerte y biometría.
- Copias de seguridad mediante Time Machine sobre disco *offline*.
- Conexión Wi-Fi WPA2, aunque con margen de mejora (véase capítulo 2).

No obstante, conviene recordar que la seguridad de un equipo *no es solo la del equipo*: una de las consideraciones que recoge el manual es que la red de la que cuelga el dispositivo forma parte de

su superficie de exposición. En este caso concreto, el hecho de que el router doméstico mantenga el botón WPS activo y la contraseña del instalador supone una vulnerabilidad relevante: un atacante en proximidad física que comprometiera la Wi-Fi podría, desde dentro de la LAN, lanzar reconocimiento contra el equipo, especialmente teniendo en cuenta que existe una regla de *port forwarding* en el puerto 3000 que expone un servicio interno al exterior.

Adicionalmente, una observación general que ya aparece en la Unidad 3 del manual: cada vez es más relevante el concepto de *software gris* —programas que sin ser clasificables como *malware* formal recopilan telemetría agresiva, modifican comportamientos del sistema sin consentimiento granular o consumen recursos sin justificación, como ciertos asistentes basados en IA integrados en el sistema operativo. El control del *rendimiento del equipo*, del consumo de recursos y del tráfico de red continúa siendo una de las técnicas de detección más útiles para este tipo de software, especialmente en perfiles de uso de desarrollo donde es habitual tener una buena visibilidad sobre los procesos en ejecución.

Capítulo 5

Buenas prácticas en Internet

Tras la lectura atenta de la *Guía de Seguridad y Privacidad en Internet* del Instituto Nacional de Ciberseguridad de España (INCIBE), accesible en <https://www.incibe.es/ciudadania/formacion/guias/guia-de-privacidad-y-seguridad-en-internet>, se han identificado tres recomendaciones — correspondientes a fichas distintas de la guía — que **no aparecen explícitamente tratadas** en las cuatro primeras unidades del manual de la asignatura. Las tres han sido seleccionadas por su relevancia práctica en el día a día digital del usuario doméstico.

Recomendación 1 — Privacidad en *wearables* y dispositivos de salud

Recomendación: al utilizar *wearables* (pulseras o relojes inteligentes), debe configurarse cuidadosamente la aplicación que gestiona el dispositivo y revisarse las opciones de privacidad de cualquier red social o plataforma con la que se sincronice, ya que estos sensores capturan datos biométricos altamente sensibles (frecuencia cardíaca, niveles de oxígeno en sangre, sueño, ubicación continua, actividad física) cuya exposición puede tener consecuencias importantes en aseguradoras o procesos selectivos.

Ficha número: 18.

Por qué no aparece en las unidades 1–4 del manual: el manual aborda en la Unidad 4 la seguridad de los dispositivos móviles en general (copias, cifrado, Bluetooth, permisos de *apps*) pero no profundiza específicamente en los *wearables* ni en el riesgo asociado a la captura masiva de datos biométricos por parte de las grandes plataformas. La ficha 18 de INCIBE cubre esta laguna.

Recomendación 2 — Uso de chats privados / cifrados en mensajería instantánea

Recomendación: en las plataformas de mensajería instantánea debe hacerse uso explícito de las opciones de “chat privado”, “chat secreto” o equivalente (Telegram *Secret Chats*, Signal por defecto, conversaciones efímeras de WhatsApp) para garantizar que el intercambio de mensajes esté cifrado de extremo a extremo y no pueda ser interceptado ni almacenado en servidores intermedios, así como configurar el autoborrado para conversaciones sensibles.

Ficha número: 10.

Por qué no aparece en las unidades 1–4 del manual: el manual cubre el correo electrónico seguro mediante PGP y S/MIME (Unidad 4, sección 2), pero no entra en las particularidades de las plataformas modernas de mensajería instantánea, que hoy concentran un porcentaje mucho mayor del tráfico de comunicación personal que el propio correo.

Recomendación 3 — Verificadores de páginas web en el navegador

Recomendación: al utilizar navegadores, instalar un “verificador de páginas web” (extensión o complemento ofrecido por la mayoría de los antivirus comerciales, o bien servicios independientes como Google Safe Browsing o las listas de Microsoft SmartScreen integradas en Edge) para añadir una capa adicional de protección que valide la reputación de los sitios web antes de interactuar con ellos. El verificador permite identificar páginas de *phishing*, suplantadas, asociadas a campañas de *malware* o con certificados sospechosos.

Ficha número: 8.

Por qué no aparece en las unidades 1–4 del manual: aunque las Unidades 3 y 4 del manual tratan el *phishing* y la navegación segura, no se mencionan los *add-ons* de reputación de URLs ni los servicios de *Safe Browsing* integrados por defecto en los navegadores modernos, que constituyen hoy la primera línea de defensa real del usuario doméstico frente a páginas maliciosas.

Capítulo 6

Conclusiones

Este capítulo final sintetiza el análisis realizado en los cuatro apartados anteriores, contrastando de manera explícita las políticas reales del entorno doméstico auditado con las recomendaciones de las cuatro primeras unidades del manual de la asignatura y de la Guía INCIBE, y propone para cada bloque las mejoras concretas identificadas.

6.1. Ordenador y sistema operativo

Resumen de lo observado: el equipo es un MacBook Air con macOS Tahoe 26.3.1 plenamente soportado, con disco cifrado mediante FileVault, contraseña fuerte de 14 caracteres, MFA y biometría activos, y copias de seguridad mediante Time Machine sobre disco externo *offline*. La política de actualizaciones es *conservadora*: descarga automática pero instalación manual trimestral. La principal anomalía es que existe una única cuenta y que esa cuenta tiene privilegios de administrador.

Contraste con las Unidades 1 a 4 del manual:

- **Gestión de contraseñas y MFA (UA 1 y UA 2).** El manual recalca el uso de contraseñas largas, complejas y combinadas con un segundo factor. La configuración del equipo — contraseña de 14 caracteres con todos los grupos, MFA con TOTP y Touch ID sobre *Secure Enclave* — se sitúa en los niveles más altos recomendados por la teoría, y refuerza la dimensión de *confidencialidad* de la tríada CIA.
- **Cifrado en reposo (UA 2).** FileVault cubre la recomendación de cifrado completo del disco que el manual considera imprescindible para proteger la información ante sustracción física del equipo.
- **Cuentas y privilegios mínimos (UA 3 y UA 4, sección 1.1.3).** El manual advierte expresamente que utilizar una única cuenta administradora para el uso diario es una de las *negligencias* más extendidas en entornos domésticos: cualquier código malicioso ejecutado por descuido heredará privilegios elevados de manera inmediata. La configuración auditada incurre exactamente en ese antipatrón.

- **Copias de seguridad (UA 4, sección 1.1.3).** El manual exige al menos un soporte *offline* para protegerse frente a *ransomware*. Time Machine sobre disco externo desconectado entre copias **cumple este requisito**, pero la **frecuencia trimestral es insuficiente**: tres meses de pérdida potencial de información son inaceptables para uso académico/profesional.
- **Actualizaciones (UA 4, sección 1.1.4).** El manual es taxativo: aplicar parches de seguridad cuanto antes y, si es posible, automáticamente. La política propia (instalación manual cada ≈ 3 meses) abre una *ventana de exposición* prolongada que el manual considera el factor de mayor riesgo en sistemas modernos.

Mejoras propuestas:

1. Crear una **cuenta estándar sin privilegios** para el uso diario, reservando la cuenta administradora para las operaciones de mantenimiento.
2. **Habilitar la instalación automática** (o aprobar manualmente en el día) de los parches de seguridad de macOS, manteniendo opcionalmente la instalación manual para actualizaciones funcionales.
3. **Aumentar la frecuencia de Time Machine al menos a una copia semanal** y considerar una segunda línea de copia cifrada en iCloud Drive (selectiva, sobre Documentos y proyectos críticos), para no depender de un único soporte físico.

6.2. Conexión a Internet

Resumen de lo observado: la conexión es de fibra Movistar a través de un HGU del operador, con NAT y filtrado de entradas activo. Existe una regla de *port forwarding* TCP/3000 hacia un servidor Express interno. La red Wi-Fi se utiliza con WPA2 y contraseña proporcionada por el instalador; WPS está activo, el SSID se anuncia y no hay filtrado por MAC. Ni la contraseña del router ni la de la Wi-Fi han sido cambiadas respecto a las de fábrica.

Contraste con la Tabla 4.1 (router) y la Tabla 4.2 (Wi-Fi) del manual:

- **Nivel Básico — Cambiar contraseña del router.** *No cumplido.* La contraseña sigue siendo la del instalador, lo que el manual considera negligencia explícita.
- **Nivel Básico — Bloqueo de conexiones entrantes (NAT).** Cumplido.
- **Nivel Básico — Evitar DMZ / *default workstation*.** Cumplido; no hay ningún equipo configurado como DMZ.
- **Nivel Medio — Configurar puertos entrantes específicos.** Cumplido en parte: existe una sola regla TCP/3000 hacia una IP privada concreta, lo cual es el modo recomendado por el manual

frente al uso de DMZ. Como mejora, dicha regla debería **desactivarse cuando no se esté usando el servidor de desarrollo**.

- **Wi-Fi, Nivel Básico — Protocolo WPA/WPA2/WPA3 con contraseña propia.** Sólo parcialmente: el protocolo es WPA2 (correcto si el router no soporta WPA3), pero la contraseña es la del instalador.
- **Wi-Fi, Nivel Básico — Desactivar WPS.** *No cumplido.* El manual considera “imprescindible” que el WPS esté completamente desactivado por sus vulnerabilidades conocidas. Esta es probablemente la mejora de mayor relación coste/beneficio.
- **Wi-Fi, Nivel Medio — Ocultar SSID, ACL por MAC, desactivar DHCP.** Ninguna de las tres medidas está implementada.
- **Wi-Fi, Nivel Avanzado — 802.1X.** No aplicable a un entorno doméstico.

Mejoras propuestas:

1. Acceder a la interfaz de administración del router (192.168.1.1) y **cambiar inmediatamente tanto la contraseña de administración del router como la clave de la red Wi-Fi**. Es la medida de mayor impacto.
2. **Desactivar el WPS** en la página de configuración Wi-Fi del router (medida crítica, fácil y sin efectos secundarios para el uso doméstico).
3. **Migrar a WPA3** cuando lo permita el firmware del router; en su defecto, mantener WPA2-AES (nunca WPA-TKIP).
4. **Desactivar la regla de port forwarding TCP/3000** cuando no se esté trabajando con el servidor Express, y limitarla mientras esté activa al menor tiempo posible.
5. Considerar **ocultar el SSID** y/o habilitar **filtrado por MAC** como segundo escalón de protección, asumiendo el ligero coste de gestión que ello supone.

6.3. Protección contra el *malware*

Resumen de lo observado: el equipo descansa principalmente en la protección nativa de Apple (XProtect, Gatekeeper, MRT, *sandboxing* y SIP), complementada para los escaneos exigidos por la práctica con Malwarebytes para Mac. Los dos escaneos completos realizados no detectaron ninguna amenaza ni PUP en $\approx 25\,720$ elementos analizados.

Contraste con la Unidad 4 (sección 1.3 “Protección contra el malware. Suites de seguridad”) del manual:

- **Empleo de *suite* de seguridad permanente.** El manual recomienda mantener activa una *suite* antimalware (puede ser la del propio fabricante del SO, como en este caso) y **revisar periódicamente el sistema con un segundo producto ligero adicional**. Esta es exactamente la configuración objetivo: XProtect + Gatekeeper permanentes, complementados con escaneos puntuales con Malwarebytes y, como mejora, con un segundo fabricante distinto.
- **Cuidado con la procedencia del software.** Cumplido: todas las aplicaciones se instalan desde App Store, fuentes notarizadas o repositorios de brew firmados.
- **Atención a la captura indebida de datos.** El manual señala que los antivirus comerciales (Avast, McAfee y otros) han sido en el pasado objeto de controversia por prácticas de recopilación de telemetría, por lo que la elección de la solución debe ser informada y la concesión de permisos restrictiva. La elección de Malwarebytes responde precisamente a este criterio.

Mejoras propuestas:

1. Realizar un **escaneo completo trimestral** fijo con Malwarebytes, no sólo cuando lo exija una práctica.
2. Añadir un **segundo escaneo regular con ClamAV** (gratuito, multifabricante, vía Homebrew) como verificación cruzada.
3. Monitorizar de forma rutinaria el **consumo de CPU y red** con *Activity Monitor* y *nettop*, como recomienda el manual, para detectar tanto *malware* clásico como *software gris* con telemetría agresiva.

6.4. Buenas prácticas en Internet

6.4.1. Contraste de nuestras políticas con TODAS las fichas de la Guía INCIBE

Una lectura completa de la guía permite identificar varias áreas en las que mis hábitos digitales están alineados con las recomendaciones de INCIBE — y otras en las que existen mejoras claras:

- **Bien cubierto:** contraseñas (longitud, complejidad, gestor en lugar de repetir credenciales), uso de MFA, cifrado de dispositivos, verificación de remitentes en correo electrónico, conciencia de *phishing* y revisión periódica de los permisos de las aplicaciones móviles. Coherente con UA 4 del manual.
- **Mejorable:** la guía insiste en separar **cuentas de correo por contexto** (laboral, personal, basura para suscripciones); en mi caso uso dos pero no tres. Habría que añadir una cuenta “de uso bajo” específica para registros y boletines.

- **Mejorable:** configuración de **privacidad granular en redes sociales** y revisión periódica de la *huella digital*. INCIBE incluye varias fichas dedicadas a esto que conviene aplicar de manera explícita, no sólo intuitiva.
- **Mejorable:** hábito de **descargar el extracto de actividad y datos almacenados** por las grandes plataformas (Google Takeout, descarga de información de Meta, etc.) al menos una vez al año, para auditar qué información tienen efectivamente sobre uno.
- **Cumplido:** no uso redes Wi-Fi públicas para tráfico sensible; cuando es imprescindible, encapsulo el tráfico mediante VPN.

6.4.2. Propuestas de actualización de la Guía INCIBE (vigente hasta 2016)

La guía no ha sido actualizada desde 2016, lo que se nota especialmente en temas tecnológicos que han evolucionado mucho en una década. Si se nos encargara una actualización, propondría las siguientes modificaciones:

1. **Ficha número: 8** (Verificadores de páginas web en el navegador).

Actualización propuesta: ampliar la ficha para incluir las protecciones nativas que ya integran los navegadores modernos — *Google Safe Browsing* en Chrome/Firefox y *Microsoft SmartScreen* en Edge —, así como la importancia de mantener actualizado el propio navegador como primera barrera de defensa frente a *phishing* y *drive-by downloads*. En la versión actual la ficha asume que el verificador es siempre un *add-on* de un antivirus de terceros, supuesto que en 2026 ya no se sostiene.

2. **Ficha número: 10** (Mensajería instantánea).

Actualización propuesta: sustituir las referencias a productos descatalogados (Line, Hangouts) por las plataformas dominantes actuales (Signal, Telegram, WhatsApp, iMessage). Explicar el modelo de **cifrado de extremo a extremo** (E2EE) como propiedad por defecto en Signal y WhatsApp y opcional (*Secret Chats*) en Telegram, y advertir sobre los riesgos específicos del *backup en la nube no cifrado* de los chats (rompe el E2EE de facto si el adversario accede al backup).

3. **Ficha número: 18** (*Wearables* y dispositivos de salud).

Actualización propuesta: extender la ficha al **ecosistema completo de Internet de las Cosas en el hogar** (asistentes de voz, cámaras inteligentes, termostatos, robots aspiradores con cámara, cerraduras inteligentes). Incorporar recomendaciones específicas sobre segmentación de red para dispositivos IoT (VLAN o red de invitados aislada), revisión de los permisos de las apps acompañantes y cuidado con los *firmwares* sin actualizaciones. El IoT doméstico es la categoría que más ha crecido desde 2016 y la guía apenas la trata.

4. **Ficha nueva propuesta (adición): Inteligencia artificial generativa.**

Actualización propuesta: introducir una ficha dedicada a los riesgos asociados al uso de servicios de IA generativa: confidencialidad del *prompt* (no incluir datos personales o sensibles), efectos

de la posible inclusión del input en los datos de entrenamiento, riesgo de *prompt injection* y de *deepfakes*, y verificación crítica de las respuestas. Es un fenómeno totalmente posterior a 2016 y completamente ausente de la guía vigente.

5. Ficha nueva propuesta (adición): Gestores de contraseñas.

Actualización propuesta: aunque diversas fichas mencionan la importancia de contraseñas robustas y únicas, ninguna recomienda de forma explícita el uso sistemático de un gestor de contraseñas (1Password, Bitwarden, KeePassXC, llavero de iCloud, etc.). Una ficha específica explicando ventajas, riesgos y buenas prácticas de uso (contraseña maestra, MFA en el gestor, copia de seguridad cifrada del *vault*) cubriría una carencia importante.

Capítulo 7

Bibliografía

Bibliografía

- [1] A. Ocón Carreras y C. Rosa Remedios, *Apuntes de Seguridad de la Información*, 3.^a ed. Universidad de Las Palmas de Gran Canaria, 2022. [En línea]. Disponible en el repositorio docente de la asignatura. Accedido: 12 de mayo de 2026.
- [2] Instituto Nacional de Ciberseguridad de España (INCIBE), *Guía de Privacidad y Seguridad en Internet*, 2016. [En línea]. Disponible: <https://www.incibe.es/ciudadania/formacion/guias/guia-de-privacidad-y-seguridad-en-internet>. Accedido: 12 de mayo de 2026.
- [3] Apple Inc., *Apple Platform Security Guide*, 2025. [En línea]. Disponible: <https://support.apple.com/guide/security/welcome/web>. Accedido: 12 de mayo de 2026.
- [4] Apple Inc., *Protecting against malware in macOS — XProtect*, soporte técnico. [En línea]. Disponible: <https://support.apple.com/guide/security/protecting-against-malware-sec469d47bd8/web>. Accedido: 12 de mayo de 2026.
- [5] Apple Inc., *Use FileVault to encrypt the startup disk on your Mac*. [En línea]. Disponible: <https://support.apple.com/HT204837>. Accedido: 12 de mayo de 2026.
- [6] National Institute of Standards and Technology (NIST), *NIST Special Publication 800-63B — Digital Identity Guidelines: Authentication and Lifecycle Management*, 2023. [En línea]. Disponible: <https://pages.nist.gov/800-63-3/sp800-63b.html>. Accedido: 12 de mayo de 2026.
- [7] WhatIsMyIPAddress, *¿Cuál es mi dirección IP?*. [En línea]. Disponible: <https://whatismyipaddress.com/es/mi-ip>. Accedido: 12 de mayo de 2026.
- [8] Movistar (Telefónica de España), *Manual de configuración del router HGU*. [En línea]. Disponible en el portal de soporte de Movistar. Accedido: 12 de mayo de 2026.
- [9] Malwarebytes Inc., *Malwarebytes for Mac — User Guide*. [En línea]. Disponible: <https://www.malwarebytes.com/mac>. Accedido: 12 de mayo de 2026.
- [10] Cisco Talos, *ClamAV Open-Source Antivirus*. [En línea]. Disponible: <https://www.clamav.net/>. Accedido: 12 de mayo de 2026.

- [11] Wi-Fi Alliance, *Wi-Fi Protected Access 3 (WPA3) Specification*, v3.0, 2020. [En línea]. Disponible: <https://www.wi-fi.org/discover-wi-fi/security>. Accedido: 12 de mayo de 2026.
- [12] Cybersecurity and Infrastructure Security Agency (CISA), *Use Strong Passwords*. [En línea]. Disponible: <https://www.cisa.gov/secure-our-world/use-strong-passwords>. Accedido: 12 de mayo de 2026.
- [13] MITRE Corporation, *Common Weakness Enumeration — CWE-521: Weak Password Requirements*. [En línea]. Disponible: <https://cwe.mitre.org/data/definitions/521.html>. Accedido: 12 de mayo de 2026.